

CVSS — Study Guide

CVSS (Common Vulnerability Scoring System) is the industry-standard framework for rating the severity of a vulnerability on a 0.0–10.0 scale. Every tool you've studied in this series — Nessus, OpenVAS, Nuclei, and your own SmartScan project's NVD integration — ultimately expresses severity in CVSS terms, so understanding exactly how the score is calculated (not just what the final number means) is genuinely foundational knowledge.

1. What CVSS Actually Measures

CVSS scores a vulnerability's severity based on its **inherent characteristics** — not how likely it is to be exploited in the wild, not your specific environment's exposure, just the technical severity of the flaw itself if successfully exploited. This distinction matters a lot and is exactly why CVSS alone isn't a complete risk picture (this is precisely the gap VPR, covered in the next guide, is designed to fill).

2. CVSS Versions

Version	Status
CVSS v2.0	Legacy, largely retired, but occasionally still referenced on very old CVEs
CVSS v3.0 / v3.1	Current industry standard, most widely used today
CVSS v4.0	Newest version (2023+), adding more nuance — adoption still growing

For study purposes, **CVSS v3.1** is what you should know cold, since it's what you'll encounter constantly in NVD, Nessus, and real reports right now.

3. The Three Metric Groups

CVSS v3.1 scores are built from three groups of metrics:

Base Metrics → intrinsic, unchanging characteristics of the vulnerability (required)
Temporal Metrics → characteristics that change over time (exploit maturity, patch availability) (optional)

Environmental Metrics → characteristics specific to YOUR environment (optional, org-customized)

Most public CVE listings (like on NVD) only show the **Base Score** — temporal and environmental scoring require organization-specific context that NVD doesn't have.

4. Base Score Metrics — Exploitability

These describe **how** an attacker would exploit the vulnerability:

Metric	Options	Meaning
Attack Vector (AV)	Network / Adjacent / Local / Physical	How remote can the attacker be? Network = worst case, exploitable from anywhere
Attack Complexity (AC)	Low / High	How much effort/luck does successful exploitation require?
Privileges Required (PR)	None / Low / High	Does the attacker need existing access/credentials first?
User Interaction (UI)	None / Required	Does a victim need to click something/take an action?
Scope (S)	Unchanged / Changed	Does the exploit affect resources beyond its own security scope? (e.g., a container escape = Changed)

This directly ties back to your CIA Triad guide — network-exploitable, no-auth-needed, no-user-interaction vulnerabilities (like EternalBlue) score extremely high specifically because every one of these metrics lands on the worst-case option.

5. Base Score Metrics — Impact

These describe **what happens** if exploitation succeeds, mapped directly onto the CIA Triad you already studied in depth:

Metric	Options	Meaning
Confidentiality (C)	None / Low / High	Data exposure impact
Integrity (I)	None / Low / High	Data tampering impact
Availability (A)	None / Low / High	Service disruption impact

This is exactly why your CIA Triad guide mentioned that CVSS's C/I/A metrics are the direct, formalized scoring implementation of that same framework — it's not a coincidence, CVSS was explicitly designed around the CIA model.

6. Putting It Together — The CVSS Vector String

Every CVSS score comes with a **vector string** that encodes every metric — this is what you'll see attached to any CVE:

```
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
```

Breaking this down:

```
AV:N → Network - exploitable remotely
AC:L → Low complexity - easy to exploit
PR:N → No privileges required
UI:N → No user interaction needed
S:U → Scope unchanged
C:H → High confidentiality impact
I:H → High integrity impact
A:H → High availability impact
```

This specific vector corresponds to a **Critical** (9.8) score — this exact combination is what EternalBlue (MS17-010) and many other worst-case vulnerabilities look like. Being able to read a vector string at a glance and immediately understand *why* something scored the way it did is a genuinely strong interview/practical skill.

7. Severity Rating Scale

Score Range	Severity
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

8. Where You'll Actually Use This

NVD (National Vulnerability Database)	→ every CVE listed has an official CVSS score + vector
Your SmartScan project	→ pulls exactly this data via the NVD API
Nessus/OpenVAS reports	→ severity ratings are CVSS-derived
Nuclei templates	→ often include a CVSS score in the `info` metadata
VAPT report writing	→ every finding needs a CVSS-justified severity rating

9. Manually Calculating a CVSS Score

The official NVD CVSS calculator (search "NVD CVSS v3.1 calculator") lets you select each metric and see the resulting score/vector build in real time — genuinely worth doing manually for 5-10 real CVEs to build intuition, rather than only ever seeing pre-calculated scores.

```
# Your SmartScan-style pattern - pulling CVSS data via the
# NVD API
import requests

response = requests.get(
    "https://services.nvd.nist.gov/rest/json/cves/2.0",
    params={"cveId": "CVE-2017-0144"}    # EternalBlue
)
data = response.json()
cvss_data = data['vulnerabilities'][0]['cve']['metrics']['cvssMetricV31'][0]['cvssData']
print(cvss_data['baseScore'], cvss_data['vectorString'])
```

10. CVSS's Known Limitations (Worth Understanding, Not Just Memorizing)

- **No exploitability-in-the-wild context** — a 9.8 CVSS vulnerability with no known public exploit may be less urgent to patch than a 7.5 with active exploitation happening right now — CVSS alone doesn't capture this
- **No environmental context by default** — a Critical vulnerability in an internet-facing service is a very different real risk than the same CVE on an air-gapped internal system, but Base Score treats them identically

- **Doesn't account for compensating controls** — a WAF, network segmentation, or other mitigations already in place aren't reflected in the Base Score
- This exact gap is precisely why **VPR (Vulnerability Priority Rating)** exists — covered in depth in the next guide, since it's specifically designed to layer real-world exploitability and threat intelligence on top of CVSS's static severity number

11. Kill Chain / ATT&CK Mapping

CVSS itself isn't a Kill Chain/ATT&CK technique — it's a **scoring framework used across every stage** where severity needs to be communicated, particularly in Reconnaissance (assessing what's exploitable) and in prioritizing which findings warrant pursuit toward Weaponization/Exploitation.

Quick Reference Cheat Sheet

AV: N(etwork) A(djacent) L(ocal) P(hysical)

AC: L(ow) H(igh)

PR: N(one) L(ow) H(igh)

UI: N(one) R(equired)

S: U(nchanged) C(hanged)

C/I/A: N(one) L(ow) H(igh)

0.0 None

0.1–3.9 Low

4.0–6.9 Medium

7.0–8.9 High

9.0–10.0 Critical